

Botium Toys: Scope, Goals, and Risk Assessment Report

Project Overview

This project involved conducting an internal cybersecurity audit for Botium Toys, a growing toy company with a physical store location and an expanding online presence.

The purpose of this audit was to assess the company's current security posture, identify cybersecurity risks, evaluate existing security controls, and provide recommendations to improve the protection of company assets, customer information, and business operations.

The assessment was based on the National Institute of Standards and Technology Cybersecurity Framework (NIST CSF). The audit focused on identifying security gaps, reviewing the effectiveness of current controls, and determining areas where additional improvements were needed to strengthen the organization's security posture and support compliance requirements.

Scope and Goals of the audit

Scope:

The scope of this audit covered the overall security program at Botium Toys. The assessment included company assets, internal systems, security controls, policies, procedures, and data protection practices.

The areas reviewed included:

- Employee devices and company equipment.
- Internal network infrastructure.
- Business applications and software systems.
- Customer and company data storage.
- Online sales and e-commerce systems.
- Physical security protections at the company location.
- Existing cybersecurity policies and procedures

Goals:

The goals of this audit were to:

- Review assets currently managed by the IT department.
 - Evaluate existing security controls and compliance practices.
 - Identify cybersecurity risks and weaknesses.
 - Determine where additional security controls are needed.
 - Provide recommendations to improve Botium Toys' overall security posture.
-

Current Assets Reviewed

The following assets managed by the IT department were reviewed:

- Office equipment used for daily business operations.
- Employee devices, including desktops, laptops, smartphones, remote workstations, and related accessories.
- Products stored in the warehouse and sold through physical and online channels.
- Business systems, including accounting, telecommunications, databases, security systems, e-commerce platforms, and inventory management systems.
- Internet access and internal network infrastructure.
- Data storage and retention systems.
- Legacy systems that require monitoring and maintenance.

Risk Assessment

Risk Score

Overall Risk Rating: 8/10 (High Risk)

The company has a high risk level because several important security controls and compliance requirements are missing or only partially implemented

Risk Description

The assessment identified weaknesses in asset management, access control, data protection, and security processes. These gaps increase the risk of unauthorized access, data exposure, business interruptions, and possible compliance issues.

Control Best Practices

Based on the NIST Cybersecurity Framework, Botium Toys should improve its ability to identify and manage company assets.

The organization should maintain an accurate inventory of hardware, software, systems, and data. Classifying assets based on importance will help the company understand which resources are critical and reduce the impact of potential security incidents.

Additional Comments

During the assessment, the following security concerns were identified:

- Botium Toys does not have complete visibility of all company assets, making it difficult to identify and protect critical resources.
- Employee access permissions are broader than necessary, increasing the risk of unauthorized access to sensitive information.
- Customer payment information is not encrypted, creating a risk of data exposure.
- Least privilege and separation of duties have not been implemented.
- Password requirements need improvement to meet stronger security standards.
- A centralized password management system is not currently available.
- Critical business data is not backed up, and a disaster recovery plan has not been established.
- An intrusion detection system (IDS) has not been implemented.
- Legacy systems are monitored, but a formal maintenance schedule is needed.
- Privacy procedures are in place, and the company has a process to notify EU customers within 72 hours after a security breach.
- Existing security controls, including firewall protection, antivirus software, CCTV monitoring, building locks, and fire protection systems, provide a strong foundation for future improvements

.

Key Security Findings

Finding	Risk Level	Impact
---------	------------	--------

Lack of encryption for customer payment data	High	Sensitive customer information could be exposed
Weak access controls	High	Employees may access information they do not need
Missing backups and disaster recovery plan	High	Business operations may be interrupted after an incident
Weak password controls	Medium	Increased risk of account compromise
Missing IDS monitoring	Medium	Security threats may not be detected quickly
Existing physical security controls	Low	Current protections reduce physical security risks

Controls Assessment Summary

The audit identified several security controls currently in place:

- Firewall protection.
- Antivirus monitoring.
- Data integrity controls.
- Physical security protections.

However, improvements are needed in:

- Access management.
- Data protection.
- Password security.
- Backup and recovery processes.
- Security monitoring.

Recommendations

Based on the audit findings, I recommend that Botium Toys:

1. Implement encryption to protect customer payment information.

2. Apply least privilege so employees only access information required for their roles.
3. Implement separation of duties for sensitive business activities.
4. Strengthen password requirements and introduce centralized password management.
5. Deploy an intrusion detection system to improve threat monitoring.
6. Create regular backups of critical business data.
7. Develop and test a disaster recovery plan.
8. Maintain an updated inventory of all company assets.
9. Establish a scheduled maintenance process for legacy systems.
10. Continue improving compliance with standards such as PCI DSS and GDPR.

Conclusion

The audit shows that Botium Toys has several important security protections in place but also has significant gaps that could affect data protection, compliance, and business continuity.

By implementing the recommended security controls, Botium Toys can reduce cybersecurity risks, improve compliance readiness, and create a stronger security foundation for future growth.